Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

David Gordillo Burrero

Convocatoria, 2025

Universidad de Extremadura

Escuela Politécnica

Ingeniería Informática en Ingeniería del Software

Trabajo Fin de Grado

Desarrollo de una herramienta para la automatización de tareas de reconocimiento en auditorías de seguridad

Autor: David Gordillo Burrero

Tutor: Tutor

Resumen

En el presente trabajo se ha desarrollado una herramienta orientada a la automatización de tareas fundamentales en auditorías de seguridad, con un enfoque específico en la fase de reconocimiento. Esta etapa, crítica en cualquier proceso de pentesting, abarca actividades como la recolección de información pasiva y activa, el escaneo de puertos y servicios, la enumeración de subdominios y tecnologías, así como la identificación preliminar de posibles vulnerabilidades.

La solución propuesta integra múltiples utilidades y técnicas ampliamente utilizadas en entornos profesionales de ciberseguridad (como Nmap, Feroxbuster, WhatWeb o WPScan), y se construye sobre una arquitectura modular y escalable que permite incorporar nuevas funcionalidades de forma sencilla en el futuro. A través de una interfaz web intuitiva, el usuario puede gestionar proyectos, ejecutar escaneos personalizados y consultar resultados de manera clara y estructurada.

Esta herramienta permite optimizar el flujo de trabajo durante las fases iniciales de una auditoría, automatizando tareas repetitivas, centralizando la información obtenida y reduciendo significativamente los tiempos de ejecución. Para ello, incorpora un sistema de inteligencia artificial basado en modelos generativos, que facilita la interacción con el contexto del escaneo para obtener recomendaciones específicas o definir próximos pasos según las debilidades detectadas. Además, genera automáticamente informes técnicos versionados, lo que simplifica la documentación del proceso y mejora su trazabilidad sin necesidad de intervención manual.

Palabras clave: Seguridad, Hacking Ético, Auditoría, Automatización, Herramienta.

Abstract

This project presents the development of a tool aimed at automating fundamental tasks in security audits, with a specific focus on the reconnaissance phase. This stage, which is critical in any penetration testing process, includes activities such as passive and active information gathering, port and service scanning, subdomain and technology enumeration, and the preliminary identification of potential vulnerabilities.

The proposed solution integrates several tools and techniques widely used in professional cybersecurity environments (such as Nmap, Feroxbuster, WhatWeb, or WPScan), and is built on a modular and scalable architecture that facilitates the future incorporation of new functionalities. Through an intuitive web interface, users can efficiently manage projects, execute customized scans, and review results in a clear and structured manner.

The tool helps optimize workflow during the initial stages of a security audit by automating repetitive tasks, centralizing collected data, and significantly reducing execution time. To achieve this, it includes an artificial intelligence system based on generative models, which allows users to interact with the scan context to receive specific recommendations or define next steps based on detected weaknesses. Additionally, it automatically generates versioned technical reports, streamlining the documentation process and improving traceability without requiring manual intervention.

Keywords: Security, Ethical Hacking, Auditing, Automation, Tool.

Índice general

1. Introducción **1**

1.1. Secciones 1

1.1.1. una subsección 2

1.1.2. otra subsección 2

1.2. Citas y referencias 2

1.3. Imágenes 2

1.4. Código 3

2. Objetivos **4**

3. Estado del Arte **5**

4. Metodología **6**

5. Implementación y desarrollo **10**

6. Resultados **11**

7. Conclusiones y trabajos futuros **12**

Anexos **13**

A. Ejemplo de anexo **14**

A.1. Sección de anexo 14

Bibliografía **15**

Índice de tablas

Índice de figuras

1.1. Logo EPCC 3

Capítulo 1

Introducción

Contenidos

1.1. Secciones **1**

1.1.1. una subsección 2

1.1.2. otra subsección 2

1.2. Citas y referencias **2**

1.3. Imágenes **2**

1.4. Código **3**

Esta plantilla sirve como ejemplo de TFE. Las secciones son las que están en la normativa, aunque si el tutor lo considera se puede cambiar la estructura. Esta sección la aprovechamos para introducir brevemente LaTeX.

1.1. Secciones

Las secciones se crean con *section*. Las subsecciones y subsubsecciones con *subsection* y *subsubsection*, respectivamente. Si se desea que alguna subsección en concreto no salga en el índice se pueden usar los mismos comandos añadiéndoles un asterisco al final (*subsection** y *subsubsection**).

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

1.1.1. una subsección

Lorem ipsum dolor sit amet, consectetuer adipiscing elit.

1.1.2. otra subsección

Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis.

subsubsecciones

¡Por defecto las subsubsecciones no aparecen en el índice! Este comportamiento se puede cambiar, pero lo recomendable es organizar los capítulos en 3 niveles para facilitar la lectura.

1.2. Citas y referencias

Para citar un texto hay que incluirlo en el fichero *LocalBibliography.bib* de esta plantilla. Una vez hecho se puede referenciar usando el comando *cite* [1]. Para referenciar imágenes, secciones o tablas se usa el comando *autoref*. Por ejemplo Figura 1.1 o Capítulo 2.

Para facilitar la lectura, cuando se insertan citas y referencias es conveniente insertar un carácter de espacio sin salto de línea ˜ antes del comando de cita o referencia.

1.3. Imágenes

Las imágenes se insertan así:

Figura 1.1: Logo EPCC.
Fuente: https://politecnica.unex.es

1.4. Código

El código se puede insertar así:

```
echo "Este es un ejemplo de cómo se inserta código con la plantilla de Trabajo
↪  Fin de Estudios de la Escuela Politécnica de Cáceres"
```

También se puede seleccionar desde un fichero, por ejemplo:

Los lenguajes reconocidos para marcar se pueden consultar en https://pygments.org/docs/lexers/. Aunque depende del tipo de trabajo, se recomienda incluir código sólo en anexos.

Capítulo 2

Objetivos

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 3

Estado del Arte

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 4

Metodología

1. Escaneo de puertos y servicios: Nmap, obteniendo los puestos abiertos del objetivo, los servicios que se encuentran corriendo en esos puertos y la version de los mismos. En caso de tratarse de un dominio en lugar de una direccion IP: 2. reconocimiento de DNS con 3 herramientas: dnsdumpster (para obtener informacion de los registros DNS principales (mx, para los proveedores de correo, ns, para los provedores de DNS y txt, para obtener metainformacion de los dominios)), mxtoolbox (para obtener informacion sobre el registro DMARC, que permite proteger el dominio de ataques de email spoofing) y apininja (para ejecutar "whois" y obtener informacion sobre la creacion del dominio, propietario, fecha de expiracion del mismo y mas metainformacion). 3. Osint de direcciones de correo: mediante 2 herramientas: IntelligenceX (para obtener direcciones de correo electronico asociadas al dominio que han sido filtradas) y leakcheck (para comprobar, en caso de que se haya obtenido alguna direccion de correo, si ha sido expuesta en alguna brecha de seguridad y que campos han sido expuestos y en que brecha en caso de que haya sido expuesta). 4. Enumeracion de subdominios, mediante la herramienta subfinder, la cual permite obtener subdominios asociados a un dominio usando diferentes motores de busqueda. Tras la enumeracion de subdominios, se utiliza "httpx" para comprobar si los subdominios encontrados estan activos, comprobando el codigo de respuesta de los mismos. Tras esto, se procede a la evaluacion de los puertos abiertos. En caso de tener el puerto 80 abierto: 5. Escaneo de vulnerabilidades web mediante nuclei, la cual

permite escanear el objetivo en busca de vulnerabilidades web y debilidades. En la herramienta implementada en este trabajo se ofrece una opcion "escaneo exhaustivo", la cual al seleccionarla lanza nuclei para todos los subdominios activos enumerados en la fase de enumeracion de subdominios, ademas del propio objetivo. Si esta opcion no se selecciona, la herramienta por defecto lanza nuclei solo para el objetivo. 6. Deteccion de "CMS" mediante la herramienta "WhatWeb", la cual permite detectar el CMS utilizado por la web del objetivo, en caso de tener. 7. Captura de pantalla del sitio web, usando "pyppeteer", una libreria de python que permite interactuar con el navegador "headless" de Google Chrome. Esto permite obtener una captura de pantalla del sitio web la cual sera adjuntada al reporte final. 8. Enumeracion de directorios y archivos, mediante la herramienta "feroxbuster", la cual permite enumerar directorios y archivos en el sitio web del objetivo. Esta herramienta permite obtener una lista de directorios que pueden ser de interes para el auditor. Al activar la opcion de "escaneo exhaustivo", feroxbuster es lanzado en recursividad de nivel 2, lo que permite enumerar directorios dentro de otros. Por defecto, si no se selecciona la opcion de "escaneo exhaustivo" feroxbuster es lanzado en recursividad de nivel 1, la cual solamente enumera directorios en la raiz del sitio web. Tras esto, se evalua el "CMS" detectado en la fase de deteccion de CMS. En caso de tratarse de Wordpress: 9. Enumeracion de wordpress, mediante la herramienta "WPScan". En esta fase se utiliza WPScan para realizar una enumeracion de debilidades, usuarios y plugins del sitio wordpress. Los usuarios enumerados seran guardados en una wordlist que se usara en posteriores fases de la herramienta para la realizacion de ataques de fuerza bruta (comprobacion de credenciales debiles). Por otra parte, para los plugins enumerados, se comprobara si existe algun repositorio publico con el CVE en Github. En caso de existir, el repositorio se clonara a la maquina desde donde se lanza la herramienta. 10. Fuerza bruta de credenciales en Wordpress, mediante la herramienta "WPScan". En esta fase se utiliza WPScan para realizar un ataque de fuerza bruta, principalmente aprovechandose del recurso xmlrpc, el cual permite realizar este tipo de ataques de manera mas efectiva, evitando medidas de seguridad como captchas o si el recurso "wp-login.php" esta protegido. Para realizar la fuerza bruta, se utiliza la

wordlist generada en la fase de enumeracion de usuarios, en caso de existir. En caso de no existir ningun usuario enumerado en el objetivo, se utiliza una wordlist por defecto con las credenciales mas comunes. En caso de que el "CMS" detectado sea Joomla: 11. Enumeracion de Joomla, mediante la herramienta "Joomscan". En esta fase se utiliza Joomscan para realizar una enumeracion de vulnerabilidades y debilidades comunes en sitios Joomla, tales como vulnerabilidades de la version instalada, archivos de backup publicos, archivos de configuracion, etc. Por otra parte, en caso de que el puerto 21 este abierto, este puerto es comunmente utilizado para FTP, un servicio que permite transferir archivos entre maquinas. En caso de que el puerto 21 este abierto: 12. Enumeracion FTP, mediante la libreria de python "ftplib". En esta fase se realiza un reconocimiento completo del servicio FTP. Se comprueba si tiene anonymous login habilitado, lo cual permitiria acceder al servidor FTP sin necesidad de credenciales. Se realiza una fuerza bruta de credenciales, utilizando wordlists personalizadas en caso de haber enumerado usuarios en fases anteriores, como en la de wordpress, o en caso de no haber enumerado ningun usuario, se utiliza una wordlist por defecto con las credenciales mas comunes. En caso de obtener acceso al servidor FTP, se comprueba si se tienen permisos de escritura y, ademas, se vuelca a la maquina local todo el contenido almacenado en el servidor. Ademas, tambien se utiliza la herramienta "searchsploit" para comprobar si existe alguna vulnerabilidad para la version del servicio FTP que esta corriendo. Por otro lado, en caso de que el puerto 22 este abierto, este puerto es comunmente utilizado para SSH, un servicio que permite acceder a la consola de la maquina de manera remota. En caso de que el puerto 22 este abierto: 13. Reconocimiento SSH. En esta fase se realiza un reconocimiento del servicio SSH. En ella, se realizara una fuerza bruta al servicio SSH mediante la herramienta "hydra". La metodologia de fuerza bruta sera la misma que se usa en fases anteriores, utilizando wordlists personalizadas en caso de existir, y en caso contrario utilizando wordlists por defecto. Ademas, se utilizara la herramienta "searchsploit" para comprobar si existe alguna vulnerabilidad para la version del servicio SSH que esta corriendo.

14. Finalmente, se generara un reporte pdf con todos los resultados anteriores, facilitando al auditor la tarea de documentar el proceso de auditoria, ademas de ofrecer

la informacion de manera estructurada y clara. Ademas, en caso de que el escaneo sea realizado desde un proyecto creado en la herramienta, los reportes generados seran versionados, permitiendo al auditor tener un control de los cambios realizados en el objetivo y la evolucion del mismo.

Ademas de esto, la herramienta implementa funcionalidades extras como: - Un sistema de inteligencia artificial basado en modelos generativos, el cual permite al auditor interactuar con el contexto del escaneo para obtener recomendaciones especificas o definir proximos pasos segun las debilidades detectadas. - Modo de "escaneo exhaustivo", el cual permite al auditor realizar un escaneo mas profundo de los objetivos, lanzando las herramientas en recursividad y obteniendo resultados mas completos. Este modo permite obtener una mayor cantidad de informacion, pero tambien realentiza el escaneo. - Configuracion de proxy: el usuario puede configurar un proxy desde la pestaña "Settings" de la interfaz grafica, el cual sera utilizado por WPScan para realizar tanto el escaneo de vulnerabilidades como la fuerza bruta. Esto ayudar a evitar bloqueos por parte del objetivo. - Sistema de proyectos: el usuario puede crear proyectos desde la pestaña "Projects" de la interfaz grafica, facilitando la gestion de los objetivos y permitiendo tener un control de los cambios realizados en un objetivo, ya que los reportes generados por escaneos desde un proyecto seran versionados.

Capítulo 5

Implementación y desarrollo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 6

Resultados

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Capítulo 7

Conclusiones y trabajos futuros

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Anexos

Anexo A

Ejemplo de anexo

Contenidos

A.1. Sección de anexo 14

Si no se desea incluir anexos, sólo hay que borrar este capítulo.

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

A.1. Sección de anexo

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Ut purus elit, vestibulum ut, placerat ac, adipiscing vitae, felis. Curabitur dictum gravida mauris. Nam arcu libero, nonummy eget, consectetuer id, vulputate a, magna.

Bibliografía

[1] Claudio Vellage. LaTeX tutorials, 2017. URL: https://www.latex-tutorial.com/tutorials/ [cited 2017-04-05].